

Digital Forensics Investigation Report

CyberDefenders — Insider Challenge

Name: Luke Brucee

Date: June 2026

Tools used: FTK Imager 8.2.0.59 SP1

1. Overview

This report documents my findings from analysing a forensic disk image as part of the CyberDefenders 'Insider' challenge. The scenario involves an employee named Karen who works at a company called TAAUSAI. After joining the company she started doing suspicious things on her work machine, and the company hired an investigator to look into it. The image provided is an AD1 disk image of Karen's Linux workstation.

The goal was to analyse the image using forensic tools, identify evidence of malicious activity, and document the findings in a structured way.

2. Case Details

Subject	Karen — employee at TAAUSAI
Hostname	KarenHacker
Operating System	Kali Linux (Debian-based)
Image filename	FirstHack.ad1
Image format	AccessData AD1 (Custom Content Image)
Image size	~85 MB (87,719,990 bytes)
Investigation period	17 March 2019 to 22 March 2019
Investigator	Luke Brucee
Tool used	FTK Imager 8.2.0.59 SP1

3. Methodology

I loaded the AD1 image into FTK Imager as an evidence item (not as a case file — I initially made the mistake of double-clicking it which caused an error, but loading it via File > Add Evidence Item > Image File worked correctly). From there I could browse the full Linux file system as a read-only mount.

I worked through the following artefact categories in order:

- OS info and user accounts
- Bash history (/root/.bash_history)
- Downloaded files (/root/Downloads)
- Desktop and Documents folders

- System logs (/var/log/auth.log)
- File timestamps

I documented findings as I went, noting file paths, timestamps, and what each artefact meant in the context of the investigation.

Note: no hash values were available for the image, so I couldn't formally verify evidential integrity. This is a limitation worth flagging in a real investigation.

4. System Overview

The machine was running Kali Linux, which is a penetration testing distribution — not something a normal employee would typically have on a work machine. The hostname was set to 'KarenHacker', which is worth noting.

The machine was configured to run entirely as root with no standard user accounts. The GNOME desktop environment was in use based on gdm-password sessions visible in the auth log.

The Apache log files (access.log, error.log, other_vhosts_access.log) were all empty — either they were wiped or the web server was never actively used.

5. Findings

5.1 Written attack plan

Probably the most significant find. In /root/Desktop/mimikatz/ there was a plaintext file called 'Checklist' containing the following:

```
Check List:
- Gain Bob's Trust
- Learn how to hack
- Profit
```

This is a clear indicator of premeditation and social engineering intent. Karen had specifically identified another employee called Bob as a target, and had written down a plan to exploit that relationship for financial gain. There was also an empty file called bob.txt in /root/Documents/myfirsthack/, which suggests she was tracking something related to Bob, though the file had no content (the bash history shows she used a malformed echo command that didn't write anything).

This is consistent with a classic insider threat scenario — using existing trust and access to facilitate an attack from the inside.

5.2 Mimikatz credential dumping toolkit

The full Mimikatz toolkit was found in two places:

- /root/Downloads/mimikatz_trunk.zip — the original downloaded archive
- /root/Desktop/mimikatz/ — the extracted contents, including mimikatz.exe (906 KB), mimidrv.sys (36 KB), and mimilib.dll (46 KB)

All files were accessed at around 03:05 on 22/03/2019 — early hours of the morning, outside normal working hours.

Mimikatz is a well-known credential dumping tool that can extract plaintext passwords, NTLM hashes, and Kerberos tickets from Windows LSASS memory. The fact it's on a Linux machine is significant — it suggests she was planning to use it against Windows machines on the same network rather than on her own machine. The package also includes

mimicom.idl which defines an RPC interface, meaning Mimikatz can be operated remotely over a network connection.

The archive also contained YARA detection rules for Mimikatz (kiwi_passwords), which suggests Karen had some awareness of how the tool is detected, implying a level of operational security knowledge.

5.3 Metasploit Framework

The bash history shows msfconsole (Metasploit) was run multiple times. More importantly, Karen also ran msfdb init to set up Metasploit's PostgreSQL database backend, and manually started and enabled the PostgreSQL service with systemctl. This isn't just someone poking at a tool — initialising the database suggests she was setting up a persistent working environment for running attacks.

5.4 PostgreSQL access attempts

The auth.log shows six rapid su postgres commands on 20/03/2019 at 11:26, all within about one second of each other. All of them failed with 'Cannot create session: Already occupied by a session'. The pattern looks automated or scripted rather than manual. This aligns with the Metasploit database setup — she was likely trying to interact with the local PostgreSQL instance.

5.5 Network reconnaissance

A script called firstscript_fixed (216 bytes, created 22/03/2019 04:05) contained basic network recon commands — checking the default route with ip route and listing connections on port 80 with netstat. The bash history also shows direct use of ifconfig and netstat. This kind of activity is consistent with someone mapping the network to identify targets before moving laterally.

5.6 Steganography

The bash history includes 'binwalk didyouthinkwedmakeiteasy.jpg' — binwalk is used to find hidden data embedded inside binary files. The image itself (1,865 KB) was in /root/Documents/myfirsthack/. The filename is clearly an attempt at humour or obfuscation. I wasn't able to fully analyse the image within this investigation but further steganographic analysis (steghide, zsteg) would be worth doing to see if anything is hidden inside it.

5.7 Sudoers modification

The auth.log records Karen running visudo on 21/03/2019 at 18:12 from /root/Documents/myfirsthack/. visudo edits the /etc/sudoers file which controls privilege escalation on Linux. It's unclear exactly what was changed without examining the sudoers file directly, but editing it could allow additional accounts or processes to gain root access — a persistence mechanism.

5.8 Bash script development

Karen created and iterated on several bash scripts in /root/Documents/myfirsthack/:

- hellworld.sh — basic script, 20 bytes, created 04:00
- firstscript — 46 bytes, initial attempt, created 04:02
- firstscript_fixed — 216 bytes, corrected version with network recon, created 04:05

The directory name 'myfirsthack' and the iterative script development suggest Karen was actively building her skills during this period. Combined with everything else, the picture is of someone in the process of learning attack techniques and applying them.

5.9 Failed login attempt

One failed authentication against the root account was recorded at 17:57 on 21/03/2019 via gdm-password. A successful keyring unlock followed at 17:57:54. Not necessarily significant on its own but worth noting in the timeline.

6. Timeline

Timestamp	Activity
17/03/2019 19:17	Earliest log entries — cron jobs running as root
20/03/2019 11:23	Karen logs into GNOME desktop as root
20/03/2019 11:26	Six su postgres attempts in rapid succession — database probing
21/03/2019 17:57	Failed root login attempt
21/03/2019 18:12	visudo run from /root/Documents/myfirsthack — sudoers edited
21/03/2019 18:19	System rebooted
22/03/2019 03:05	Mimikatz extracted to /root/Desktop/mimikatz/
22/03/2019 04:00–04:05	Bash scripts created in /root/Documents/myfirsthack/
22/03/2019 04:11	bob.txt created (empty)
22/03/2019 04:18	Checklist file created — social engineering plan documented
22/03/2019 15:57	didyouthinkwedmakeiteasy.jpg accessed — binwalk run on it

7. Indicators of Compromise

mimikatz.exe	/root/Desktop/mimikatz/ — 906 KB, accessed 22/03 03:05
mimidrv.sys	/root/Desktop/mimikatz/ — 36 KB
mimilib.dll	/root/Desktop/mimikatz/ — 46 KB
mimikatz_trunk.zip	/root/Downloads/ — original download
firstscript_fixed	/root/Documents/myfirsthack/ — network recon script
Checklist	/root/Desktop/mimikatz/ — written social engineering plan
bob.txt	/root/Documents/myfirsthack/ — empty, associated with target 'Bob'
didyouthinkwedmakeiteasy.jpg	/root/Documents/myfirsthack/ — suspected steganography

8. Conclusions

Based on the artefacts recovered, Karen was deliberately and systematically preparing to conduct an attack against TAAUSAI's infrastructure. The evidence shows clear progression

— from installing tools, to writing scripts, to staging credential dumping software, to documenting a social engineering plan targeting a specific colleague.

Key takeaways:

- The written checklist is the clearest indicator of premeditation and intent.
- Mimikatz on a Linux machine almost certainly means she was planning to attack Windows systems on the same network — it's not useful otherwise.
- The 03:00-05:00 activity window on 22/03 suggests deliberate out-of-hours operation to avoid detection.
- No confirmed data exfiltration was found, but the investigation has limitations — particularly around network traffic and steganographic analysis.

9. Recommendations

- Run steganographic analysis on `didyouthinkwedmakeiteasy.jpg` (steghide, zsteg) to check for hidden data.
- Check the `/etc/sudoers` file for any changes made during the visudo session on 21/03.
- Interview or review communications from the employee referred to as 'Bob' — if social engineering contact has already occurred it needs to be established.
- Review network logs for outbound traffic from KarenHacker's IP during the investigation period.
- Check Windows endpoints on the same network segment for signs of Mimikatz execution.
- Deploy Mimikatz YARA signatures across corporate endpoints as a detection measure.

10. Limitations

- No image hash was available so evidential integrity can't be formally confirmed.
- The AD1 format is proprietary — only FTK Imager was used; ideally a second tool would cross-validate findings.
- Network traffic wasn't available, so lateral movement conclusions are inferred rather than observed.
- Memory forensics wasn't performed.
- The contents of `didyouthinkwedmakeiteasy.jpg` weren't fully analysed.